# Technical Review Board (TRB) Charter – Acme Health Plan

| Document control | |
|---|---|
| Document ID | CHARTER-2026 |
| Document type | TRB Charter |
| Date | 2026-04-01 |
| Status | Active |
| Classification | Internal – Synthetic Sample |

> Acme Health Plan is fictional. This is a synthetic sample document for the Databricks Feature Tracker.

**Organization:** Acme Health Plan
**Effective Date:** April 1, 2026 (platform-baseline reviews began April 21, 2026)
**Last Revised:** July 1, 2026 (added Exception/Waiver process and Re-review/Sunset notices)

---

## 1. Purpose and Scope

The Technical Review Board (TRB) is established to evaluate the security, compliance, and operational suitability of new Databricks features and capabilities for use within Acme Health Plan, particularly those with implications for member data handling, integrations, and HIPAA compliance.

The TRB operates as a governance body ensuring that technology decisions align with:
- HIPAA Security Rule, Privacy Rule, and Breach Notification Rule
- Acme Health Plan's risk tolerance and member data protection standards
- Architectural quality and operational sustainability
- NIST Cybersecurity Framework (800-30 risk methodology, 800-66 HIPAA guidance)

**PHI Eligibility Rule:** Features are PHI-eligible **only when** Databricks release phase = GA **AND** TRB status = Approved (with or without conditions, provided conditions are verified met).

## 2. Authority and Governance

The TRB reports to the Chief Information Security Officer (CISO) and provides recommendations to the Executive Steering Committee. All TRB decisions regarding PHI-eligible features are binding; recommendations for non-PHI features are advisory.

## 3. Composition

| Role | Count | Appointed By |
|---|---|---|
| CISO (Chair) | 1 | Chief Executive Officer |
| Chief Privacy Officer (CPO) | 1 | General Counsel |
| Enterprise Architect | 1 | Chief Technology Officer |
| Platform Engineering Lead | 1 | VP of Engineering |
| Data Governance Lead | 1 | Chief Data Officer |
| Compliance Officer | 1 | CISO |
| Business Unit Representative (Rotating) | 1-2 | Requesting department head |

## 4. Responsibilities

**Charter Governance:**
- Interpret and apply HIPAA Security Rule safeguards to Databricks features
- Define the Databricks release phase → TRB status → PHI-eligibility mapping
- Establish review criteria, timelines, and escalation paths
- Approve or reject conditions and exceptions

**Individual Reviews:**
- Evaluate feature requests against security, compliance, and operational readiness criteria
- Assess inherited vs. shared vs. customer-specific security controls (per AWS Shared Responsibility Model)
- Identify and document binding conditions for approval
- Resolve exceptions and waivers

## 5. Review Criteria

**For All Features:**
- HIPAA compliance posture (administrative, technical, physical safeguards)

- Authentication, authorization, and access control architecture
- Audit logging and monitoring capabilities
- Dependency chain (inherited controls from Databricks, AWS, and partner integrations)
- Operability, support model, and incident response readiness

**For PHI-Eligible Features (Phase = GA only):**
- Encryption in transit and at rest; key management
- Row-level and column-level data masking/filtering capabilities
- User identity validation and session management (MFA, re-authentication)
- Compliance documentation completeness (risk assessment, conditions verification)
- Business continuity, disaster recovery, and failover readiness

## 6. Decision Framework

| TRB Status | Definition | Implications | Use with PHI? |
|---|---|---|---|
| **Not Reviewed** | Request not submitted or intake incomplete | Feature not approved for use; pilot only with explicit exception | ❌ No |
| **Under Review** | Intake received; risk assessment underway | Pilot permitted: ≤5K rows, ≤90 days, non-PHI only | ❌ No |
| **Rejected** | Feature does not meet Acme Health Plan standards (phase too early, compliance risk unacceptable) | No use; resubmit only if Databricks phase advances or risk factors fundamentally change | ❌ No |
| **Approved** | All criteria met; no conditions or all conditions verified | Full use per Databricks phase; PHI-eligible if phase = GA | ✅ Yes (if GA) |
| **Approved with Conditions** | Approval contingent on documented conditions being satisfied | Use permitted only when conditions verified met; TRB spot-checks continue quarterly | ✅ Yes (if GA + conditions met) |
| **Retired** | Feature end-of-life or compliance conditions became unmet | No new deployments; existing deployments enter documented sunset period (≤180 days) | ❌ No (existing access wound down) |

## 7. Meeting Schedule

- **Cadence:** Biweekly on Tuesdays, 10:00 AM ET
- **Scheduled Meetings (2026):** Apr 21, May 5, May 19, Jun 2, Jun 16, Jun 30 (platform baseline); Jul 14, Jul 28, Aug 11, Aug 25, Sep 8, Sep 22, Oct 6
- **Intake Deadline:** ≥5 business days prior to meeting
- **Quorum:** ≥4 members including CISO or CPO
- **Decision Authority:** Unanimous required for PHI-eligible reviews; majority vote for advisory reviews

## 8. Conditions and Exceptions

**Conditions** are requirements tied to an "Approved with Conditions" decision. They must be satisfied and verified before the feature is used in production or with PHI. Conditions are tracked by ID (COND-[review#]-[n]) and remain in effect indefinitely or until explicitly waived.

**Exceptions** are temporary or limited-scope waivers of a TRB decision (e.g., early GA use, expanded user base, limited PHI scope). Exceptions require unanimous TRB vote, documented risk mitigation plan, and automatic sunset (not to exceed 180 days unless renewed). Exception IDs: EXC-2026-[NNN].

## 9. Review Lifecycle

```
Intake → Risk Assessment → TRB Meeting → Vote → Decision Record & Conditions →
Implementation & Verification → Monitoring (Quarterly) → Renewal/Sunset
```

1. **Intake (Week 0):** Business unit submits form via [Ticket System] with feature name, Databricks phase, use case, estimated data volume, PHI scope.
2. **Assignment (Day 2):** TRB Lead (Enterprise Architect or Privacy Officer) assigned; kick-off meeting with requestor.
3. **Risk Assessment (Week 1-2):** Lead completes NIST 800-30 security & privacy assessment; meets with requestor for clarifications.
4. **Board Preparation (Day -2):** All materials (intake, risk assessment, risk calculation matrix) distributed to TRB members.
5. **TRB Meeting (Scheduled):** Requestor presents (15 min); board discusses (15 min); vote (5 min).
6. **Decision Record (Day +1):** CISO signs decision record with conditions (if any) and condition verification timelines. Requestor notified via Conditional Approval Letter.

7. **Condition Verification (Per timeline):** Requestor executes conditions; TRB lead verifies (audit logs, test queries, training certificates, etc.). Verification report sent to requestor.
8. **Closure & Monitoring:** Decision record marked "Approved"; monitoring begins (quarterly audit of logs and condition compliance).
9. **Annual Re-Review (Optional):** Year 1 anniversary, TRB may issue re-certification notice; requestor re-affirms conditions are met and no new risks emerged.

## 10. Escalation and Dispute Resolution

- **Level 1 (TRB Reconsideration):** Requestor may request TRB reconsideration if new evidence or Databricks product changes presented. Requires unanimous TRB consent to reopen.
- **Level 2 (Executive Steering Committee):** If TRB rejects unanimously, requestor may escalate to [Executive Steering Committee] via exception request. Executive committee may override only with CISO and CPO concurrence; all risk acceptance documented.
- **Resolution SLA:** Level 1 resolved within 10 business days; Level 2 within 20 business days.

## 11. Compliance Framework

TRB operations incorporate:

- **HIPAA Security Rule (45 CFR §§ 164.308-314):** Administrative (workforce, training, audit, incident response), Technical (authentication, encryption, access controls, audit logs), and Physical (facility, device, media) safeguards.
- **NIST SP 800-30 Risk Management Guide:** Risk identification, analysis (likelihood × impact), mitigation, and residual risk acceptance.
- **NIST SP 800-66 HIPAA Security Rule Implementation:** Guidance on administrative, technical, and physical safeguard implementation for healthcare IT.
- **AWS Shared Responsibility Model:** Acme Health Plan responsible for "security in the cloud" (data access controls, encryption keys, user access, audit logs); AWS responsible for "security of the cloud" (data center, hypervisor, network infrastructure).
- **Acme Health Plan Data Governance Policy [POLICY-2024-DG]:** Organization-specific data classification, retention, and sharing rules.

## 12. Review and Revision

This charter shall be reviewed annually (July) and revised as needed to reflect regulatory guidance updates, organizational risk tolerance adjustments, or lessons learned from reviews and incidents. Revisions require CISO and CPO approval.

---

**Approved By:**
[CISO Name], Chief Information Security Officer
Signature: _____ Date: July 1, 2026

[CPO Name], Chief Privacy Officer
Signature: _____ Date: July 1, 2026

---

**Attestation:** This charter was approved by Acme Health Plan's Executive Steering Committee per governance policy [POLICY-2024-GOV] and represents the authoritative decision-making framework for technology review and compliance at Acme Health Plan.

**Classification:** Internal – Synthetic Sample